

Лабораторная работа №7

Анализ трафика HTTP и HTTPS с помощью анализатора Wireshark

Цель работы

Целью данной лабораторной работы является изучение особенностей передачи данных по протоколам HTTP и HTTPS, а также практическое освоение методики перехвата и анализа сетевого трафика средствами утилиты tcpdump и анализатора Wireshark, в том числе сравнение возможностей анализа открытого и зашифрованного трафика прикладного уровня.

Задачи работы

В ходе выполнения работы решались следующие задачи: подготовка рабочей среды на базе виртуальной топологии EVE-NG; перехват сетевого трафика на интерфейсе узла Kali Linux средствами утилиты tcpdump во время взаимодействия с веб-сервером по протоколу HTTP; анализ полученного дампа в анализаторе Wireshark с выделением передаваемых пользовательских данных формы аутентификации; повторный перехват трафика во время аналогичного взаимодействия по протоколу HTTPS и сопоставительный анализ зашифрованного трафика.

Ход работы

Подготовка рабочей среды

В среде эмуляции EVE-NG была развёрнута сетевая топология, включающая узел под управлением операционной системы Kali Linux, подключённый через единственный сетевой интерфейс к сегменту с выходом в сеть Интернет. На узле Kali командой ifconfig был определён используемый для подключения сетевой интерфейс — eth0 — с назначенным IP-адресом 192.168.26.129/24 и MAC-адресом 00:50:00:00:02:00. Корректность сетевого

подключения подтверждена успешным прохождением ICMP-пакетов до публичного DNS-сервера 8.8.8.8.

Перехват и просмотр HTTP-трафика

На узле Kali Linux в приложении терминала с привилегиями суперпользователя была запущена утилита `tcpdump` командой `sudo tcpdump -i eth0 -s 0 -w httpdump.pcap`. Параметр `-i eth0` указывает интерфейс перехвата, параметр `-s 0` устанавливает длину моментального снимка по умолчанию (262144 байта), что обеспечивает захват пакетов полного размера, параметр `-w` задаёт имя файла для записи перехваченного трафика в формате pcap (рис. 1).

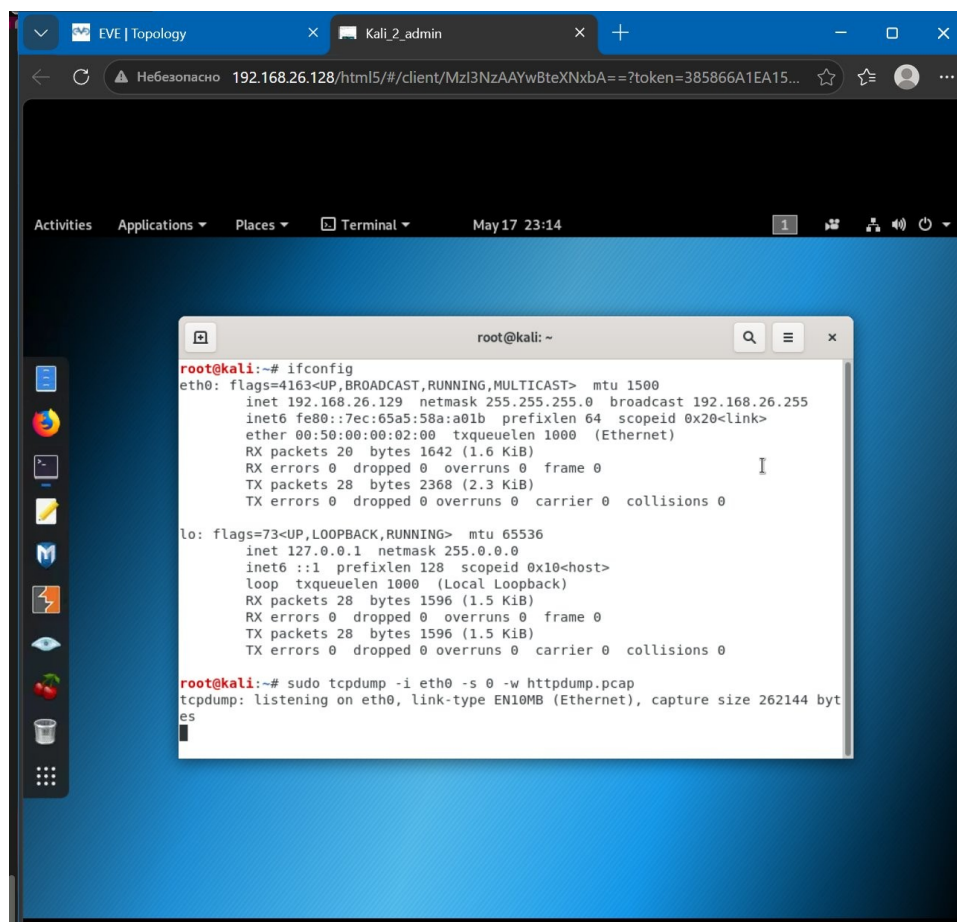


Рис. 1. Определение интерфейса узла Kali Linux и запуск утилиты `tcpdump`

Для генерации HTTP-трафика на узле Kali был запущен веб-обозреватель Mozilla Firefox, в адресной строке которого был выполнен

переход по адресу *http://demo.testfire.net/login.jsp* — действующий демонстрационный веб-сайт системы AltoroMutual, предоставляемый компанией HCL Technologies в качестве учебного стенда для исследования веб-уязвимостей (исходный ресурс *altoromutual.com:8080*, указанный в методических указаниях, в настоящее время недоступен и был выведен из эксплуатации). На загруженной странице авторизации веб-обозреватель отобразил всплывающее окно с предупреждением «This connection is not secure. Logins entered here could be compromised», подтверждающее факт передачи учётных данных по незащищённому протоколу (рис. 2).

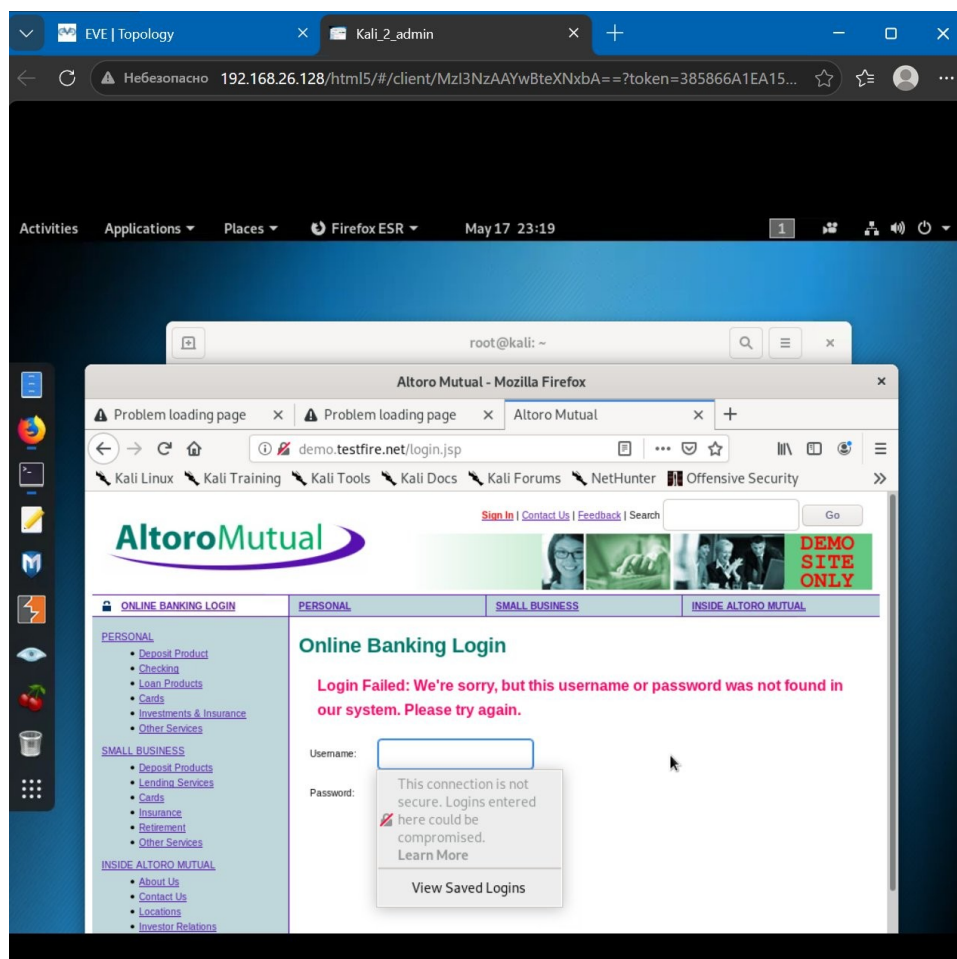


Рис. 2. Веб-страница AltoroMutual при подключении по протоколу HTTP

В поля Username и Password были введены учётные данные тестового пользователя jsmith и Demo1234 соответственно, после чего была нажата кнопка Login. Авторизация прошла успешно, веб-сервер вернул главную

страницу личного кабинета с приветствием «Hello John Smith». Веб-обозреватель был закрыт, в окне терминала с работающей утилитой tcpdump было выполнено прерывание процесса перехвата комбинацией клавиш CTRL+C. По окончании работы утилитой было зафиксировано 7291 захваченных кадров без потерь со стороны ядра операционной системы (рис. 3).

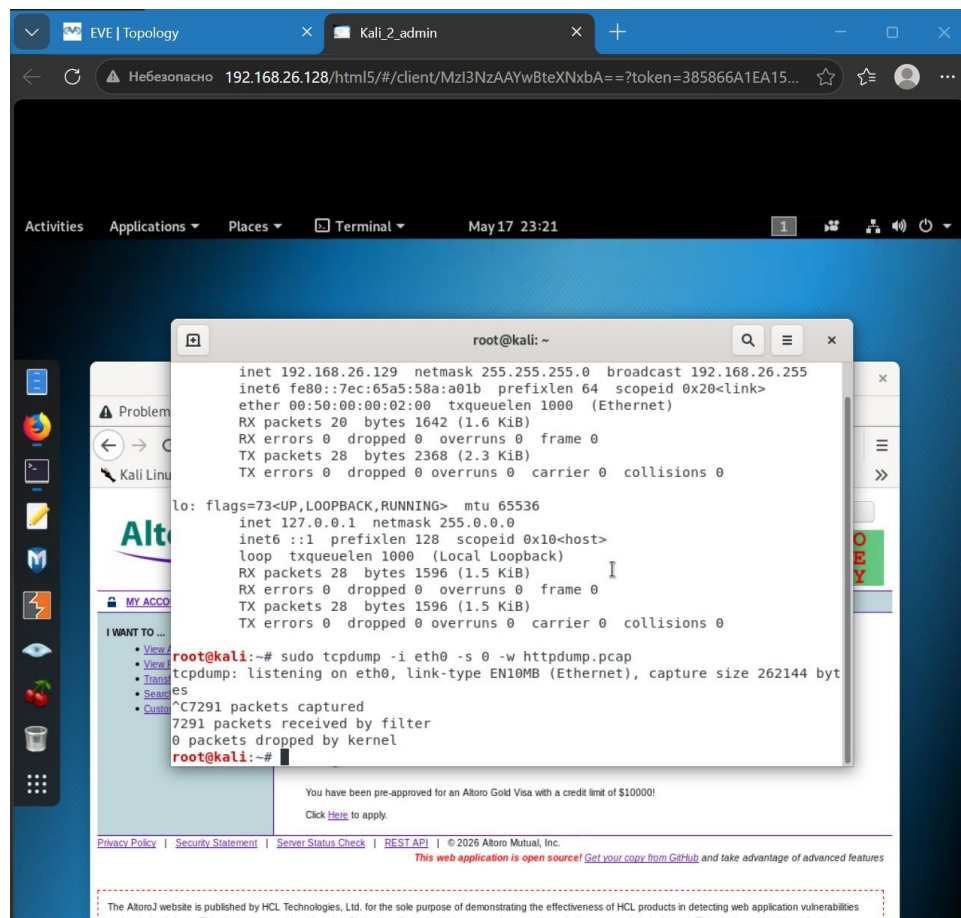


Рис. 3. Завершение захвата сетевого трафика на интерфейсе eth0

Полученный файл httpdump.pcap, расположенный в домашней папке пользователя, был открыт в анализаторе Wireshark. В поле фильтра отображения было введено значение *http* и применено нажатием клавиши Enter, в результате чего в списке пакетов остались только сообщения прикладного уровня по протоколу HTTP. Среди отображённых пакетов был найден и выделен пакет с методом *POST /doLogin*, соответствующий отправке заполненной формы аутентификации с веб-обозревателя на сервер.

В нижней панели подробного содержимого пакета был развёрнут раздел HTML Form URL Encoded: application/x-www-form-urlencoded, в котором в открытом виде в кодировке URL отображены параметры формы: имя пользователя *uid=jsmith*, пароль *passw=Demo1234*, а также служебный параметр кнопки отправки формы *btnSubmit=Login* (рис. 4).

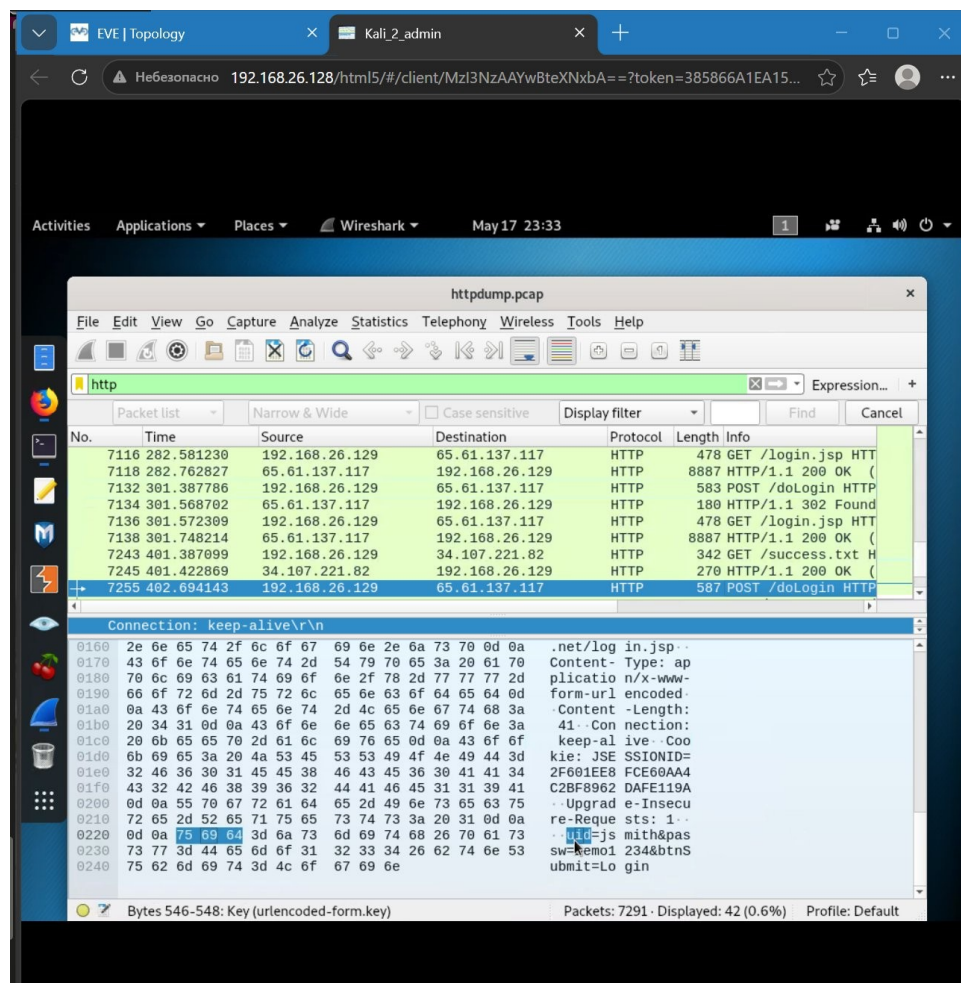


Рис. 4. Содержимое сообщения HTTP POST с параметрами формы аутентификации в открытом виде

Указанные параметры формы переданы веб-обозревателем в составе тела HTTP-сообщения POST без какого-либо шифрования или иного преобразования, что в полной мере соответствует особенностям работы протокола HTTP, не предусматривающего средств обеспечения конфиденциальности передаваемых данных. Любое промежуточное сетевое устройство, имеющее доступ к проходящему через него сетевому трафику,

имеет возможность получить логин и пароль пользователя в готовом для использования виде.

Перехват и просмотр HTTPS-трафика

Для перехвата HTTPS-трафика в приложении терминала была повторно запущена утилита `tcpdump` командой `sudo tcpdump -i eth0 -s 0 -w httpsdump.pcap` с записью результатов в файл `httpsdump.pcap`. После запуска утилиты в веб-обозревателе была открыта защищённая версия того же ресурса — `https://demo.testfire.net/login.jsp`. В адресной строке веб-обозревателя обозначен факт использования протокола HTTPS, отображён значок замка. В поля формы были введены те же учётные данные `jsmith` и `Demo1234`, авторизация прошла успешно, веб-сервер вернул главную страницу личного кабинета (рис. 5).

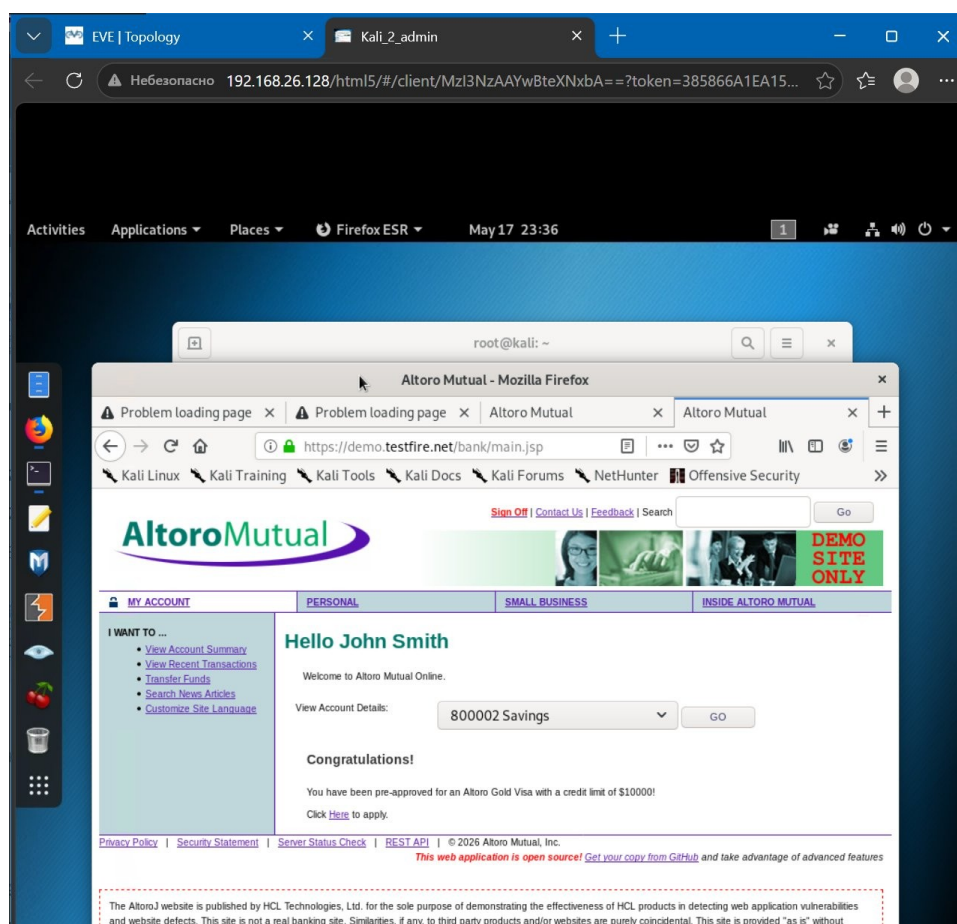


Рис. 5. Веб-страница AltoroMutual при подключении по протоколу HTTPS

Веб-обозреватель был закрыт, перехват трафика остановлен комбинацией клавиш CTRL+C. Полученный файл `httpsdump.pcap` был открыт в анализаторе Wireshark, в поле фильтра отображения введено значение `tcp.port==443`, соответствующее общепринятому номеру порта TCP, на котором веб-серверы принимают входящие подключения по протоколу HTTPS. В отличие от предыдущего записанного файла, в списке отображённых пакетов отсутствуют сообщения прикладного уровня по протоколу HTTP — вместо них отображены сообщения протокола TLSv1.2 (Transport Layer Security версии 1.2) с типом Application Data, представляющие собой защищённую инкапсуляцию HTTP-сообщений в туннеле TLS (рис. 6).

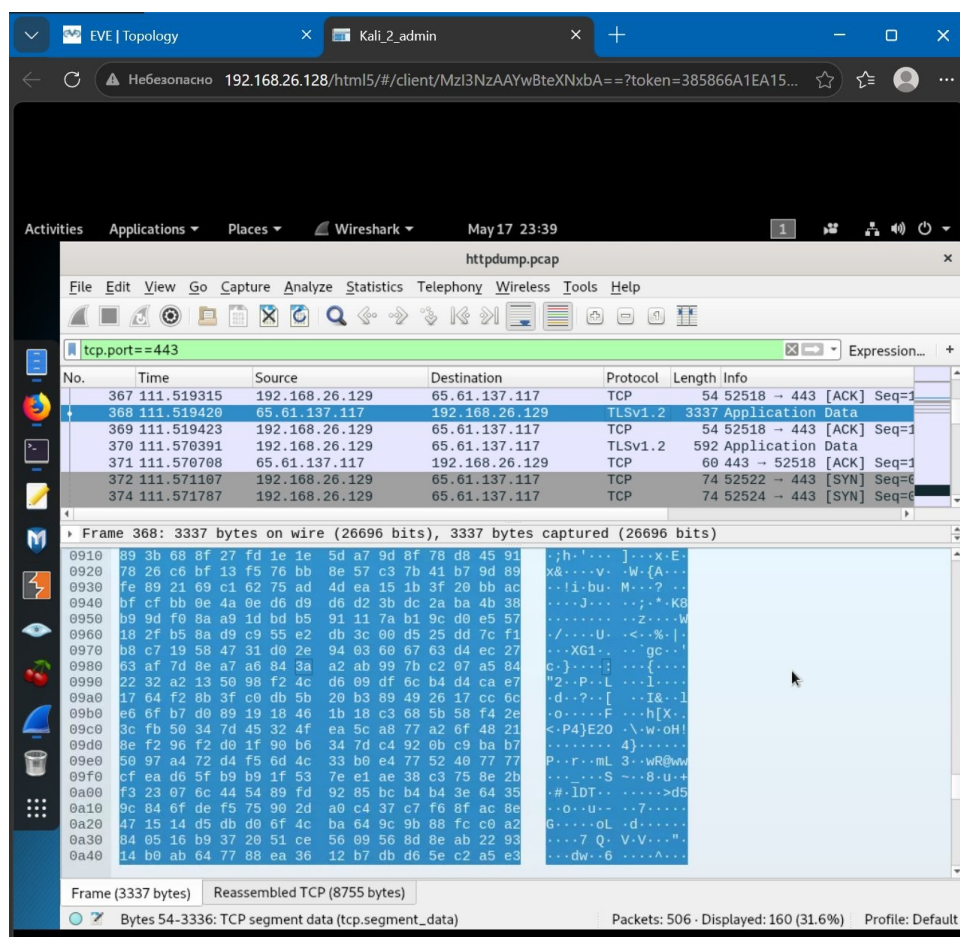


Рис. 6. Сообщения HTTPS-трафика, отфильтрованные по номеру порта 443

В нижней панели подробного содержимого выделенного пакета TLSv1.2 был полностью развёрнут раздел Transport Layer Security, в котором отображены метаданные TLS-записи: тип содержимого Application Data (значение поля 23), версия протокола TLS 1.2 (0x0303), длина зашифрованных данных приложения (8750 байт), а также непосредственно поле Encrypted Application Data, представляющее собой последовательность шестнадцатеричных значений, не поддающуюся непосредственному прочтению (рис. 7).

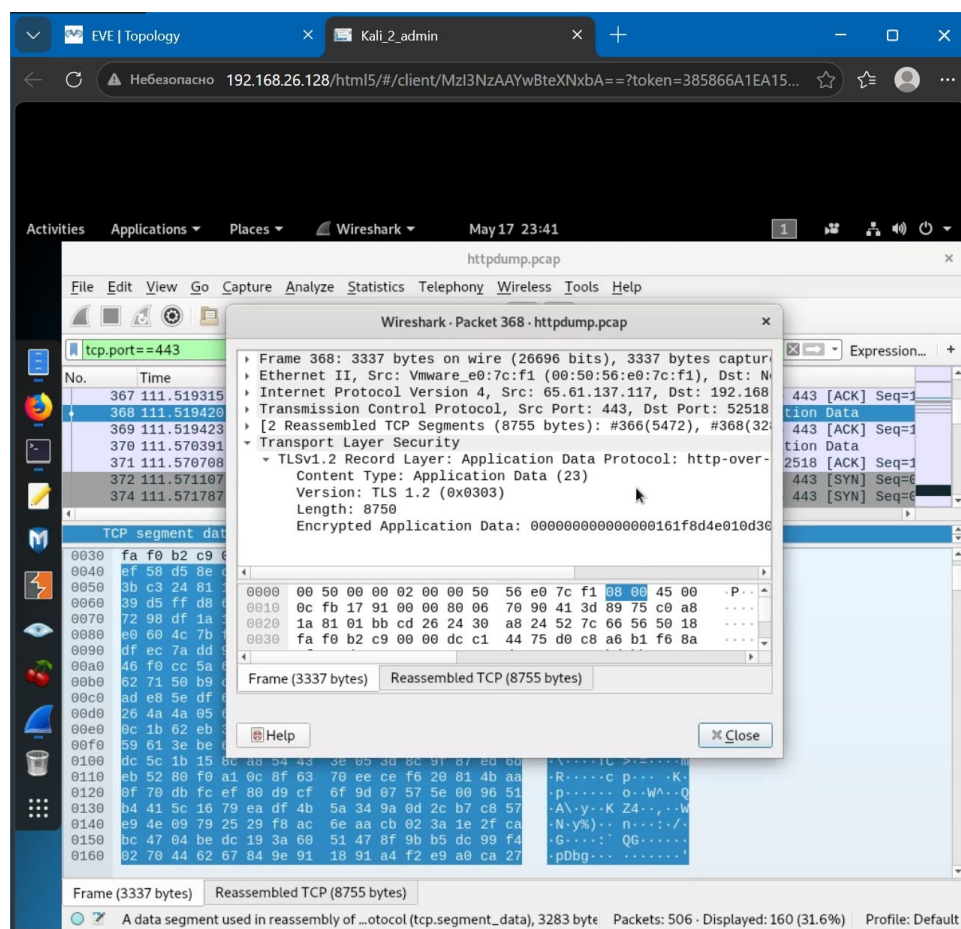


Рис. 7. Содержимое сообщения HTTPS: раздел Transport Layer Security и зашифрованные данные приложения

Параметры формы аутентификации (логин и пароль), переданные узлом в составе HTTP POST-запроса, оказались инкапсулированы в шифрованную TLS-запись и недоступны для непосредственного прочтения средствами анализатора Wireshark. Расшифровка указанных данных

возможна исключительно при наличии закрытого ключа сервера либо закрытых ключей сессии TLS, недоступных по умолчанию для промежуточных сетевых устройств в проводящем сегменте сети.

Вывод

В ходе выполнения лабораторной работы был перехвачен и проанализирован сетевой трафик, формируемый узлом Kali Linux в процессе взаимодействия с демонстрационным веб-приложением AltoroMutual по протоколам HTTP и HTTPS. Перехват сетевого трафика выполнен средствами утилиты tcpdump с записью в файлы формата pcap, последующий анализ — средствами анализатора Wireshark с применением фильтров отображения по протоколу прикладного уровня и по номеру TCP-порта.

Экспериментально подтверждена незащищённость протокола HTTP применительно к передаче чувствительных данных пользователя. В перехваченном HTTP-трафике средствами Wireshark было обнаружено сообщение HTTP POST со ссылкой /doLogin, в теле которого в открытом виде содержались параметры формы аутентификации: логин uid=jsmith и пароль passw=Demo1234. Указанные значения доступны для непосредственного прочтения в анализаторе без необходимости какой-либо дополнительной обработки, что демонстрирует возможность компрометации учётных данных пользователя при их передаче по незащищённому протоколу через произвольный сегмент сети.

Также экспериментально подтверждена эффективность защиты, обеспечиваемой протоколом HTTPS на основе механизма TLS. В перехваченном HTTPS-трафике вместо сообщений протокола HTTP отображаются сообщения протокола TLSv1.2 с типом Application Data, содержащие зашифрованные данные приложения. Параметры формы аутентификации, переданные тем же образом, что и в предыдущем эксперименте, оказались инкапсулированы в защищённый TLS-туннель и

недоступны для прочтения средствами анализатора Wireshark в отсутствие закрытых ключей сессии. Помимо собственно конфиденциальности передаваемых данных, протокол TLS обеспечивает их целостность и аутентификацию сервера посредством его цифрового сертификата.

Проведённое сопоставительное исследование подтверждает практическую невозможность анализа содержимого HTTPS-трафика средствами пассивного перехвата на промежуточных сетевых устройствах, что обуславливает повсеместное использование протокола HTTPS в современной сети Интернет применительно к веб-приложениям, обрабатывающим персональные данные, учётные данные пользователей, финансовую и иную чувствительную информацию.